

Manual 25 — Implementação Controlada de Gestão de Continuidade de Negócios ISO 22301

Tradução de projeto pt-BR — não oficial.

01. Propósito, escopo e limite de uso controlado

Estabeleça um modelo prático de implementação do SGCN sem reproduzir texto normativo da ISO nem implicar certificação, conformidade legal ou opinião de auditoria.

02. Hierarquia de fontes e controle de versões

Mantenha um registro de fontes que separe ISO 22301:2019, Emenda 1:2024, orientação ISO 22313, política interna, requisitos contratuais, sobreposições regulatórias e material de acompanhamento de mudanças.

03. Contexto da organização

Identifique questões internas e externas que afetem a capacidade de continuidade, incluindo dependências, ambiente operacional, partes interessadas, contexto relacionado ao clima quando relevante e restrições estratégicas.

04. Partes interessadas e obrigações

Mantenha um inventário controlado de expectativas de continuidade de clientes, reguladores, contratos, força de trabalho, fornecedores e setor público, com responsáveis e evidências.

05. Escopo e limites do SGCN

Defina unidades organizacionais, serviços, locais, tecnologias, fornecedores, dados, instalações e exclusões dentro do limite do sistema de gestão de continuidade de negócios.

06. Liderança e responsabilização

Atribua patrocínio executivo, propriedade de políticas, direitos de decisão, autoridade de escalonamento, responsabilidade de financiamento e responsabilização por evidências.

07. Política de continuidade de negócios

Mantenha uma política aprovada alinhada aos objetivos organizacionais, escopo, obrigações, expectativas de resiliência e compromissos de melhoria contínua.

08. Funções, responsabilidades e competência

Defina funções responsáveis por continuidade de negócios, liderança de crise, proprietários de serviços, recuperação tecnológica, instalações, comunicações, jurídico, RH, compras e assurance.

09. Planejamento para riscos e oportunidades

Identifique riscos e oportunidades no nível do SGCN que possam afetar os resultados pretendidos do sistema de gestão e defina tratamentos acompanhados.

10. Governança da análise de impacto nos negócios

Estabeleça metodologia de BIA, cadência de revisão, controles de qualidade de dados, autoridade de aprovação e ligação com inventários de serviços e estratégias de recuperação.

11. Produtos e serviços críticos

Identifique produtos, serviços, atividades e fluxos de valor prioritários, incluindo tolerâncias aceitáveis de interrupção e impactos sobre partes interessadas.

12. Critérios de impacto e dimensões temporais

Defina critérios financeiros, jurídicos, de segurança, clientes, operacionais, regulatórios, reputacionais e de missão ao longo de intervalos temporais de interrupção.

13. Dependências e requisitos de recursos

Mapeie pessoas, instalações, tecnologia, dados, utilidades, fornecedores, logística, comunicações e dependências especializadas necessárias para atividades priorizadas.

14. Avaliação de riscos de interrupção

Avalie cenários de interrupção, vulnerabilidades, pontos únicos de falha, risco de concentração, exposição geográfica, dependências cibernéticas/físicas e efeitos em cascata.

15. Seleção de estratégias de continuidade

Selecione estratégias proporcionais com base nos resultados de BIA e riscos, equilibrando resiliência, capacidade de recuperação, custo, complexidade e risco residual.

16. Continuidade de pessoas e força de trabalho

Defina alternativas de pessoal, sucessão, treinamento cruzado, capacidade de trabalho remoto, bem-estar, viagens, acesso, segurança e controles de comunicação com a força de trabalho.

17. Instalações e resiliência física

Trate espaços alternativos de trabalho, utilidades, controles ambientais, segurança física, acesso a locais, diversificação geográfica e dependências de recuperação de instalações.

18. Integração de recuperação tecnológica e cibernética

Integre objetivos do SGCN com recuperação de desastres, backup, restauração, resposta a incidentes cibernéticos, recuperação de identidade, resiliência de infraestrutura e dependências de aplicações.

19. Continuidade de informações e dados

Proteja disponibilidade, integridade, recuperabilidade, retenção, confidencialidade e acesso controlado às informações necessárias durante interrupção e recuperação.

20. Continuidade de terceiros e cadeia de suprimentos

Defina requisitos de continuidade para fornecedores, due diligence, evidências, revisão de risco de concentração, sourcing alternativo, escalonamento, cláusulas contratuais e reavaliação.

21. Estrutura de gestão de crises

Defina funções estratégicas, táticas e operacionais de crise, critérios de ativação, estrutura de comando, registro de decisões, transições e escalonamento executivo.

22. Procedimentos de resposta a incidentes e continuidade

Mantenha procedimentos utilizáveis para ativação, estabilização, continuidade, recuperação, escalonamento, coordenação de recursos e encerramento.

23. Comunicações e gestão de partes interessadas

Defina comunicações internas e externas, autoridade do porta-voz, aprovação de mensagens, notificações a reguladores/clientes, manutenção de contatos e controle de rumores.

24. Objetivos de recuperação e prioridades de restauração

Traduza tolerâncias empresariais aprovadas em objetivos operacionais de recuperação, sequenciamento, necessidades mínimas de recursos e prioridades validadas de restauração de serviços.

25. Documentação e acessibilidade dos planos

Assegure que os planos estejam atuais, controlados, disponíveis em condições degradadas, adequadamente protegidos, versionados e compreensíveis aos usuários pretendidos.

26. Treinamento e conscientização

Implemente conscientização baseada em função, desenvolvimento de competências, integração, reciclagem, preparação de liderança de crise e evidência de conclusão.

27. Programa de exercícios e testes

Mantenha um programa baseado em risco usando walkthroughs, simulações, testes técnicos de recuperação, exercícios com fornecedores, exercícios de crise e cenários integrados.

28. Achados de exercícios e remediação

Registre observações, causas raiz, responsáveis por ações, prazos, risco residual, requisitos de reteste e evidência de encerramento para achados de exercícios e incidentes.

29. Monitoramento, medição e métricas

Defina indicadores do SGCN para prontidão, atualidade dos planos, desempenho de recuperação, efetividade de exercícios, resiliência de fornecedores, envelhecimento de problemas e atingimento de objetivos.

30. Auditoria interna e assurance

Planeje assurance independente e baseado em evidências sobre desenho e operação do SGCM, preservando competência do auditor, escopo, amostragem, achados e limites de acompanhamento.

31. Análise crítica pela direção e melhoria contínua

Forneça à liderança evidências sobre desempenho, mudanças, incidentes, exercícios, resultados de auditoria, riscos, recursos, objetivos e ações de melhoria.

32. Publicação, evidência e roteiro de implementação

Empacote um roteiro de implementação Essencial / Estruturado / Aprimorado com verificação de fontes, mapeamento de controles/evidências, acompanhamento de problemas, localização, acessibilidade, proveniência, checksum, segurança de workflows e gates de release. Revalide o estado das fontes ISO imediatamente antes da publicação e trate ISO/CD 22301 e ISO/AWI 22313 como acompanhamento de mudanças não normativo enquanto não forem formalmente publicados.